

SYSTEM INTEGRATION PRACTICES

Security Integration



Instructor: Huy Nguyen Dang Quang, Msc

Email: huyndq@duytan.edu.vn

REF: Shawn A. Butler, Ph.D

Senior Lecturer, Executive Education Program
Institute for Software Research
Carnegie Mellon University

Lecture Objectives

- ❑ Understand some of the essential elements of security
- ❑ Identify some of the problems integrating security architectures

Agenda

- ☐ A quick overview of security
- ☐ Authentication
- ☐ Access Control
- ☐ Auditing
- ☐ IPv?

A quick overview of security

- **The problem:** The demand for data exchange is increasing and diversified
=> Data protection measures are also renewed.
- **Methods:** administrative measures, techniques, algorithms (most effective)
- **Guarantee:** confidentiality, authenticity, responsibility

- Security holes
- Weak passwords
- Shared files
- No firewall
- Data is not encrypted
- Virus, Worm and Trojan Horse

1. Zero-Day Vulnerability

A **zero-day vulnerability** is a security flaw in software or a system that the vendor is unaware of and for which no patch exists yet.

- Hackers discover it first and can exploit it immediately.
- It is called "Zero-Day" because the **day it is discovered is the same day it is attacked**, giving developers zero days to prepare.

Example: A hacker finds a flaw in the Chrome browser and uses it to install spyware before Google releases a patch.

2. SQL Injection: is an attack that injects malicious SQL code into the system via input fields (login forms, search boxes, etc.).

Attackers exploit code that does not properly validate or sanitize input, allowing them to send arbitrary SQL commands to the database.

Example: Suppose a login form:

- Username:
- Password:

A weak check in code like: `SELECT * FROM users WHERE username = 'user_input' AND password = 'pass_input';`

An attacker enters:

- Username: admin' --
- Password: (anything)

The SQL becomes: `SELECT * FROM users WHERE username = 'admin' --' AND password = 'anything';`

(Note: -- starts a comment in SQL, so everything after it is ignored.)

Result: The attacker can log in as admin without knowing the password!

❑ External

- Malicious Code
- Hackers
 - White hat hackers –Finds flaws and reports to vendor
 - Black hat hackers –Finds flaws and exploits it
 - Gray hat hacker –Finds flaws and may/may not exploit it
- Industrial Spies
- Distributed Denial of Service Attacks
- Customers
- Environmental

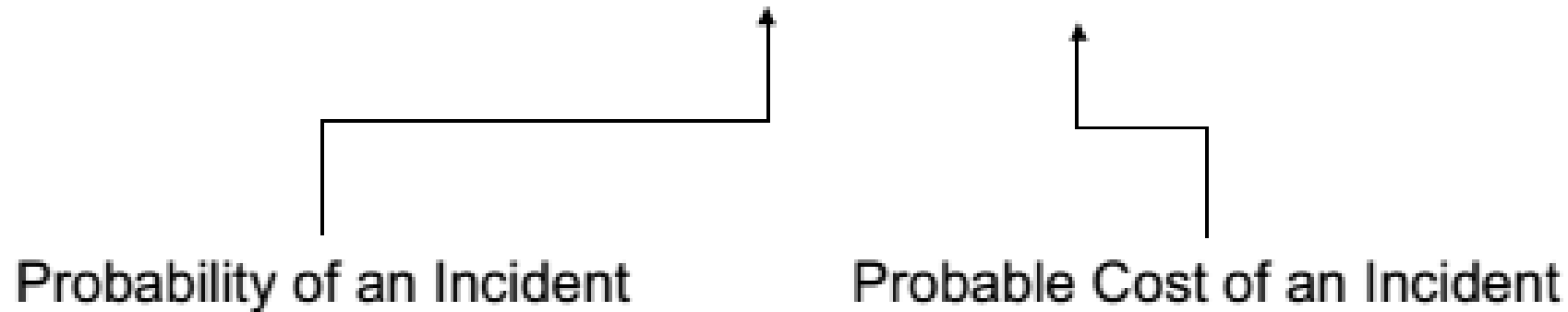
❑ Internal

- Employees
- Contractors
- IT personnel
- Developers

- ☐ Greed
- ☐ Curiosity
 - Violation of Privacy Policies
- ☐ Spying
- ☐ Intellectual Challenge
- ☐ Anarchy

What is Risk?

$$\text{Risk} = P(\text{Event}) * P(\text{Loss})$$



- What are the incidents I care about?
- How do I determine the probability
- How do I estimate the cost
- How do I reduce risk

Example:

- If the probability of the system being attacked by malware is **5% (0.05)** and the expected cost for recovery and losses is **\$100,000**, the risk is calculated as follows:
- **Risk = 0.05 × 100,000 = 5,000**

This means the estimated financial risk from this incident is **\$5,000**.

State-of-the-Practice Security Architecture Design Decisions

- Risk management methods and security engineering principles *guide* selection of risk mitigation controls for a system's security architecture
- The purpose of risk management is to ensure that security risks are brought to an acceptable level
- The system security architecture are the policies, procedures, and technologies that mitigate the risk
- State-of-the-practice offers quantitative and qualitative risk-management methods

❑ Qualitative: Threats are high, medium, or low risk.

Reading:

- *Risk Management Guide (National Institute of Standards and Technology)*
- *OCTAVEsm (Software Engineering Institute)*

❑ Quantitative: Expected asset damage is assessed probabilistically assessed.

Reading:

- *OCTAVEsm (Software Engineering Institute)*
- *Annualized Loss Expectancy (ISC2)*
- *Security Attribute Evaluation Method (SAEM)*

- Support security design principles
- Cost and effectiveness
 - Maintenance
 - Skill level
 - Out source
- Organizational adoptability
- Marginal benefit
- Due diligence

- **Authentication** - The determination of claimed identity
- **Authorization** - The determination of access to resource(s)
- **Non-repudiation** - The prevention of a principal from denying participation
- **Security Protocols** - The rules that govern communications between principals
- **Trust** - Confidence that the principals' activities will be protected and conducted as intended

- **Prevention** – Prevention is preferred over detection and recovery
- **Completeness** – Consider all assets when designing the security architecture
- **Defense in breadth and depth** – Countermeasures should be deeply staggered and widespread
- **Reduce external relationships** – Dependencies on others introduce vulnerabilities
- **Integration** – Countermeasures should be seamlessly integrated
- **Anticipation** – Your risk environment will change
- **Simplicity** – The KISS principle applies

☐ Prevention

- Security training
- Establish security policies

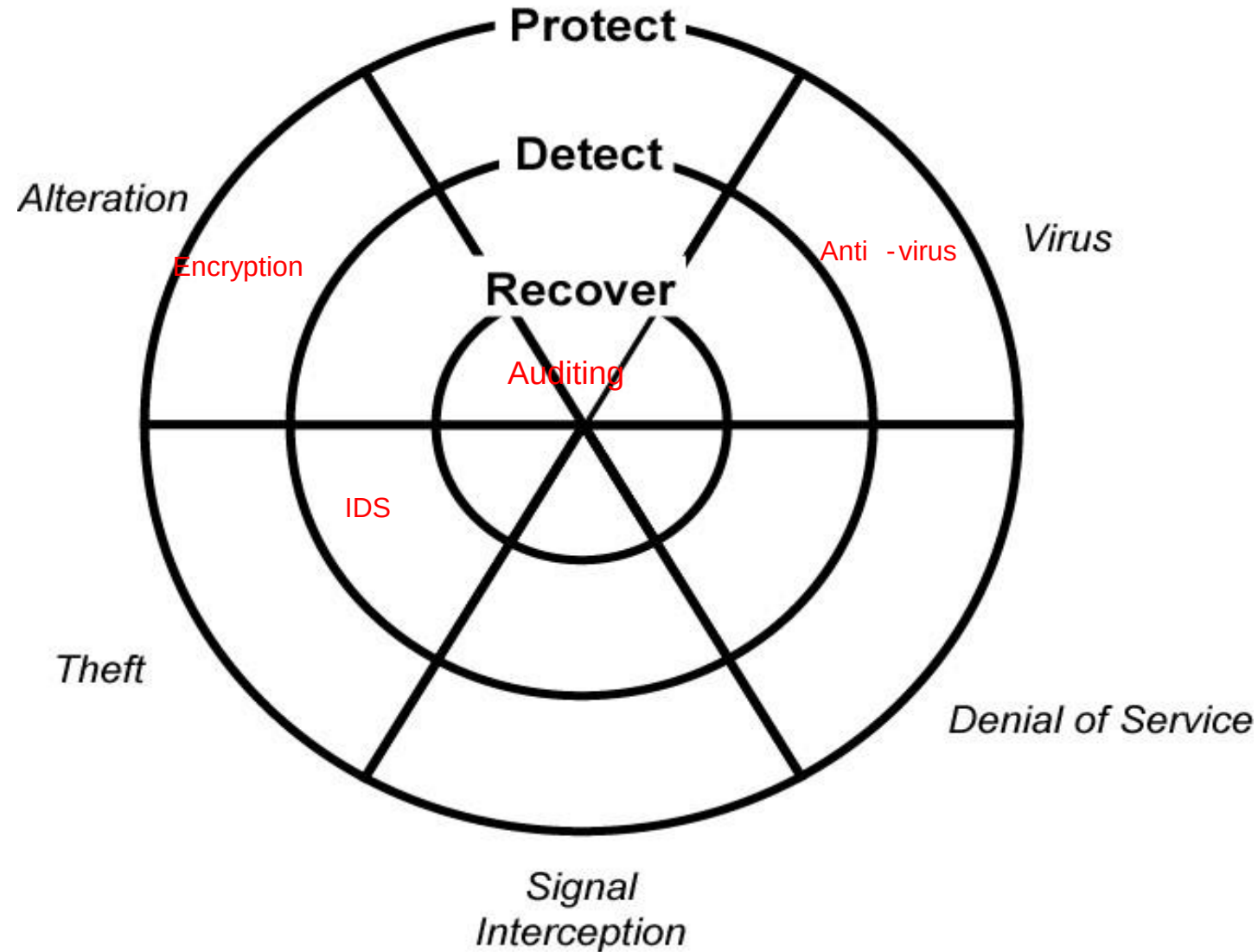
☐ Detection

- Conduct periodic reviews
- Conduct audits
- Conduct ongoing risk assessments

☐ Recovery

- Continuity of operations
- Incident response

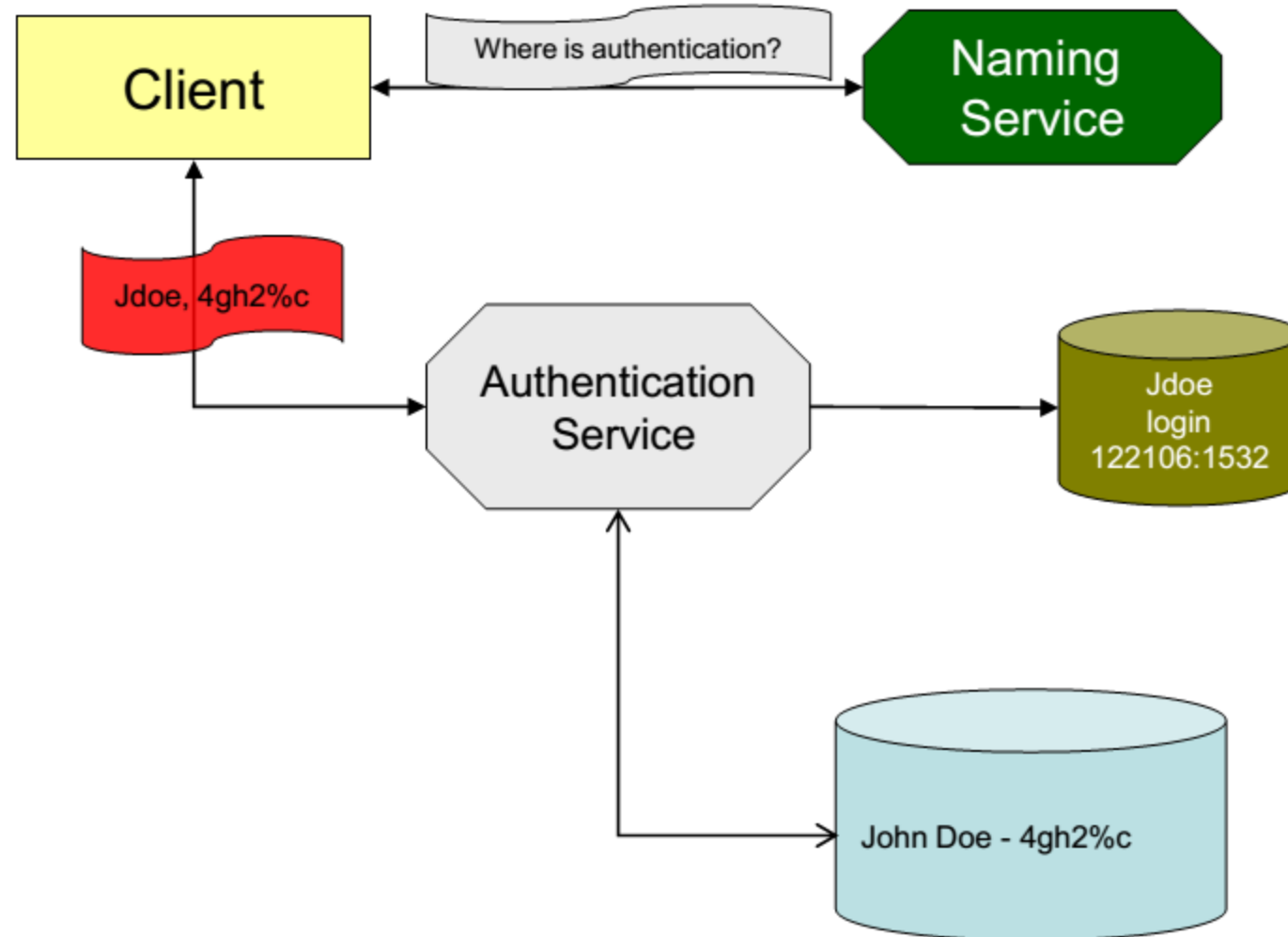
Defense-in-Depth



What do we trust?

- Trust that the other principal is really who it claims to be – **Authentication and Authorization**
- Trust the process and mechanisms by which principals communicate - **Encryption**
- Trust the information exchanged – **Data Integrity**
- Trust the other principal will not deny participation in the exchange – **Non-repudiation**

Authentication



- ***Who you know*** –Someone trusted can vouch for you **such as User ID, Password, Smart Cards, Biometrics**
- ***What you have*** –Something you received that you would have had to shown proof of identify, **such as a passport**
- ***What you are*** –Uniquely identifying marks, **such as birthmarks, teeth x-rays, etc.**
- ***Where you are*** –Your physical location **such as IP, Mask,...**

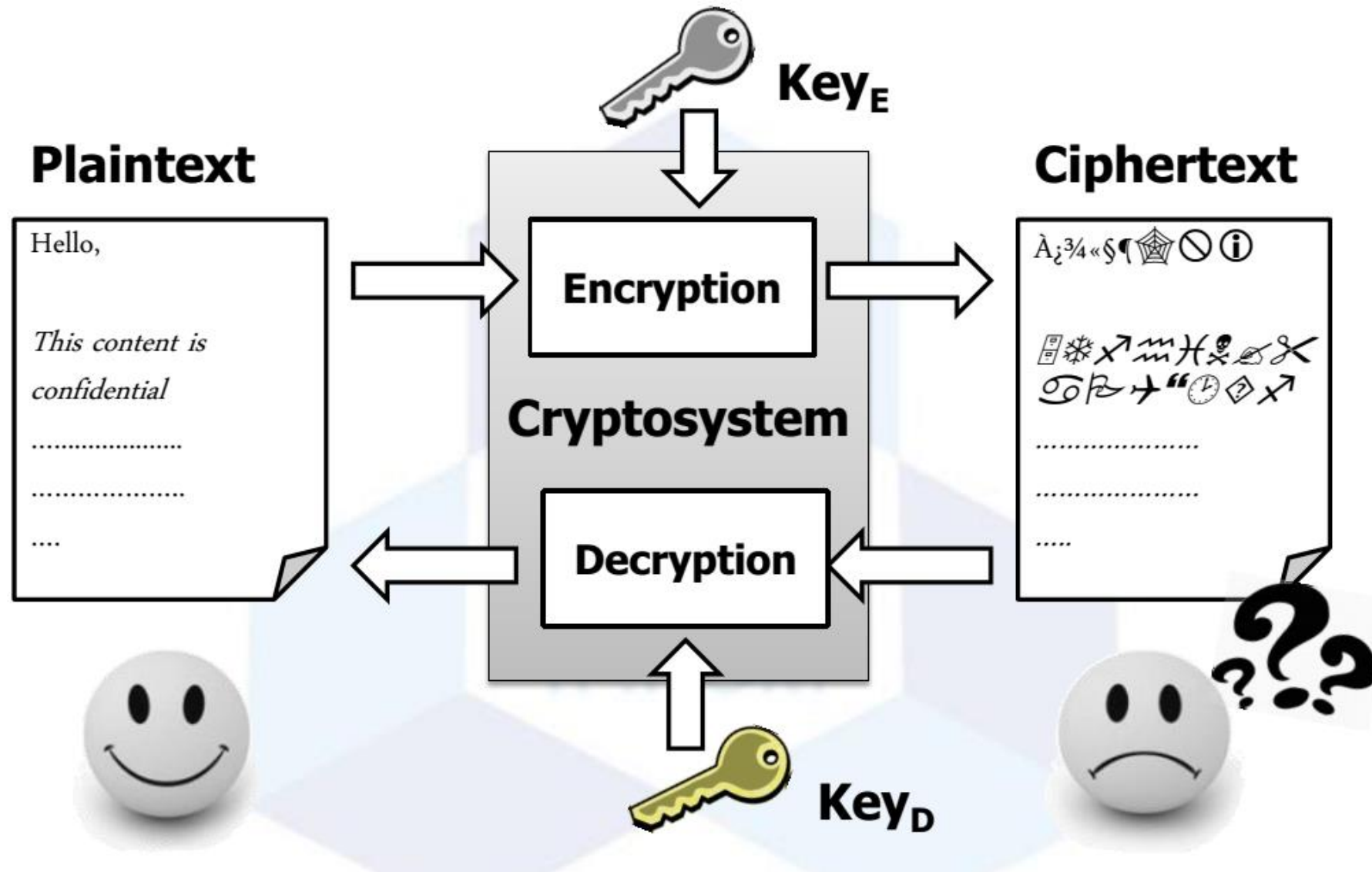
- Decentralized authentication
 - OAuth 2.0, OpenID Connect
- Multi-Factor Authentication (MFA)
 - Use OTPs (One-Time Passwords) or biometrics (fingerprint, facial recognition).

Related Technologies: Google Authenticator, Microsoft Azure AD.

- What is an acceptable password?
- How often must the user change the password?
- How many times can a user attempt logon?
 - What is the business cost?
- What is the process for getting an initial password?
- What forms of verification are acceptable?
- How does the user re-establish access after forgetting the password?
- Will you enforce or encourage good password selection?
- How many different passwords?

Single Sign-on?

Encryption system



Symmetric-key Cryptography

- *It is a class of encryption algorithms where both encryption and decryption use the same key.*
- **Illustrative example:** Two users, Alice and Bob, are communicating over a channel (such as the Internet, WIFI, or mobile phones).

The real problem begins when a malicious woman named Eve accesses the channel, for instance, by hacking into a router or intercepting the signals from a Wi-Fi connection =====> **Eavesdropping**

- Naturally, Alice and Bob still want to communicate over the internet without letting Eve know the content of their conversation
- **Encryption technology** provides an effective solution: Alice encrypts her message using a symmetric algorithm, generating a ciphertext. Bob then receives this ciphertext and decrypts it to retrieve Alice's message. In this way, **decryption** is the reverse process of **encryption**..

- **Symmetric Encryption** (also known as **secret-key encryption**) is an encryption method where the encryption key and decryption key are the same (the same secret key is used for both encryption and decryption).
- This is the most common method used today for encrypting data transmitted between two parties. Since the secret key is sufficient for decryption, both the sender and receiver must agree on the secret key in advance.
- Common symmetric encryption techniques include: DES, 2DES, 3DES, Triple DES, **AES**, RC4, RC5/RC6, **ChaCha20**, **Blowfish**

Symmetric-key Cryptography

Algorithm	Status	Notes
AES	Very popular	Secure, fast, widely used
DES	Obsolete	No longer secure
3DES	Old, slow	Being phased out
Blowfish	Good, free	Heavily used in password encryption
RC4	Not recommended	Vulnerable to attacks
RC5/RC6	Rarely used	Was once an AES candidate
ChaCha20	Secure, fast	Stream cipher, replacement for RC4, high performance on devices without hardware encryption support

❑ Advantages

- The encryption and decryption algorithms can be fast in both hardware and software
- Keys are relatively short
- Ciphers can be used to generate pseudo-random numbers, hash functions, and digital signatures
- Ciphers can be combined to create very secure encryption

❑ Disadvantages

- Key distribution is a problem
- Key must be replaced often
- Not administratively easy for digital signature algorithms

- ❑ **Asymmetric Encryption** (also known as **public-key encryption**) is an encryption method where the encryption key (called the **public key**) and the decryption key (called the **private key**) are different..
- ❑ This means that the key used to encrypt the data is not the same as the key used to decrypt it.
- ❑ Everyone, including hackers, can know the public key and use it to encrypt information. However, only the recipient, who holds the private key, can decrypt the information.

An asymmetric encryption system is also referred to as a public-key cryptosystem.

Asymmetric Key Encryption Techniques

A common asymmetric encryption technique is:

- **RSA(Rivest, Shamir, and Adleman)**
- **ECC (Elliptic Curve Cryptography)**
- **ElGamal**
- **DSA (Digital Signature Algorithm)**

Asymmetric Key Encryption Techniques

Algorithm	Primary Purpose	Key Feature	Status
RSA	Encryption & Signatures	Easy to implement, popular	Standard
ECC	Encryption & Signatures	Compact, fast, strong	New trend
ElGamal	Encryption & Signatures	Longer keys, good security	In use
DSA	Digital Signatures	Not used for encryption	Specialized

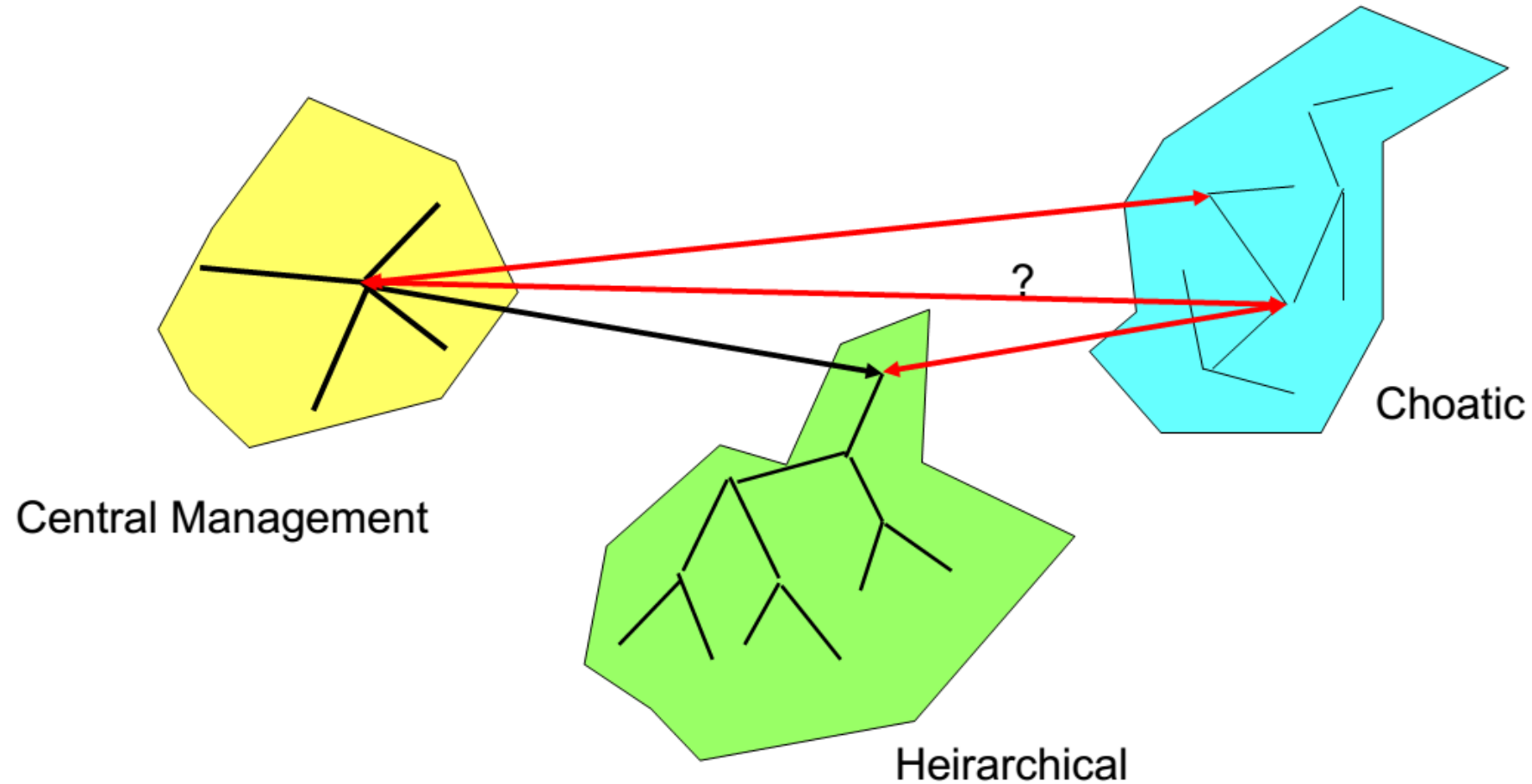
- **Advantages**

- The encryption and decryption algorithms can be fast in both hardware and software
- Keys are relatively short
- Ciphers can be used to generate pseudo-random numbers, hash functions, and digital signatures
- Ciphers can be combined to create very secure encryption

- **Disadvantages**

- Key distribution is a problem
- Key must be replaced often
- Not administratively easy for digital signature algorithms

Key Management Infrastructure



- What objects can you access?
- What can you do to objects?
- What can you allow others to do?
- What can the group access?
- What can the group do to the object?
- What can group members allow others to do?
- What is the lowest level of control?

- Principle of Least Privilege
- Subjects, Objects, Capabilities, Roles
- Mandatory, Discretionary, Role Based Access Control
- Two Models for Multi-level Security
 - Bell-LaPadula Model – No Read up: No Write down
 - Biba Model – No Write up – Read up only

- Different access control mechanisms are often not compatible
- Changes in sensitivity levels of information
- Data aggregation
- Merging directories is not trivial
- Access control decision rules are based on a pre-existing assumption of authentication trust
- Granularity of accessible objects

- Account logon events
- Account management
- Object access
- Policy change
- System events
- Use centralized monitoring systems like SIEM (Security Information and Event Management) such as Splunk or IBM QRadar.
- Establish log retention policies that comply with GDPR and HIPAA.

- What events are being logged?
- How much additional space will be required?
- Will old logs still be accessible?
- Are the logs semantically equivalent?
- Do logs overlap?
- Is there a specific reason for logs?

Summary

- Integration of security services is difficult and takes considerable planning
- Integration of security services may introduce more risk than the risk of each component
- Authentication, access control, and auditing are the fundamentals of system security
- Not all system integration tasks involve security, but when they do, find a security engineer with experience

The end

THANK YOU